QA QUEST

BIBLIOTECA DE ESTUDOS / MATERIAL DE APOIO

Teste de Segurança

Proteja identidades, permissões e informações. Aprenda a observar riscos e transformar comportamentos em evidências.

01
Entender

02
Verificar

03
Registrar

TRILHA 03 · QUALIDADE ESPECIALIZADA

MÓDULO 02 · TESTE DE SEGURANÇA

Guia introdutório · 6 páginas · v1.0 · 01/11/2026

Material complementar. Não contém respostas das missões.

01 / ENTENDA O CONCEITO

O que é Teste de Segurança?

Segurança vai além de conseguir entrar: importa também o que cada conta pode acessar.

Teste de Segurança investiga falhas e riscos que possam comprometer a **confidencialidade, integridade e disponibilidade** de sistemas e informações. Em QA, verificamos se os controles se comportam conforme requisitos e limites de permissão.

- **Confidencialidade:** Apenas pessoas autorizadas veem determinada informação.
- **Integridade:** Dados e operações não sofrem alterações indevidas.
- **Disponibilidade:** Serviços permanecem utilizáveis segundo os requisitos definidos.

Três conceitos para não confundir

Conceito	Pergunta	Exemplo
Autenticação	Quem é esta pessoa?	Conta válida entra com credenciais de teste.
Autorização	O que pode acessar?	Usuário comum não edita registros de admin.
Sessão	Como o acesso permanece?	Após sair, área privada exige novo login.

ATENÇÃO AO CONTROLE REAL

Estar autenticado não dá acesso a todos os recursos. Esconder botões na interface **não** substitui a verificação de permissão no servidor.

02 / ORGANIZE O TESTE

Planeje testes seguros e objetivos

Cenário didático: LeituraLivre, uma biblioteca digital totalmente fictícia.

A LeituraLivre tem contas de associados **A** e **B** e uma conta administrativa de teste. Cada associado deve visualizar somente seus próprios empréstimos. O objetivo é testar essa regra sem utilizar dados reais.

Antes de executar

- **Autorização explícita:** valide escopo, ambiente e responsáveis pelos testes.
- **Dados fictícios:** prepare contas e registros sem informações de terceiros.
- **Critérios claros:** defina comportamentos permitidos e negados.
- **Limites:** combine volume, evidências permitidas e interrupção segura.

Matriz introdutória de casos

Caso	Condição	Resultado esperado
SEG-01	Conta A consulta seus empréstimos.	Permite visualizar somente os próprios dados.
SEG-02	A solicita um registro privado de B.	Nega acesso e não expõe dados de B.
SEG-03	Visitante abre área privada.	Nega ou redireciona com segurança.
SEG-04	Associado solicita ação de admin.	Nega ação; nenhuma alteração é salva.

UMA DISTINÇÃO ÚTIL

401 costuma indicar ausência de autenticação; **403**, ausência de permissão. Alguns sistemas retornam **404** para não revelar o recurso. O resultado esperado depende do requisito e do desenho da API.

03 / EXECUTE E REGISTRE

Da observação à evidência

Um bom achado precisa ser reproduzível e compreensível sem expor informações privadas.

A execução compara **o que deveria ocorrer** com **o que realmente ocorreu**. Uma interface pode esconder opções corretamente e, ainda assim, um serviço precisar de verificações adicionais de permissão.

SOLICITAÇÃO
Conta de teste tenta uma ação

→

VERIFICAÇÃO
Servidor valida identidade e permissão

→

RESPOSTA
Permite ou nega sem vazar dados

Exemplo de registro (fictício)

Campo	Registro
Identificação	SEG-02 · LeituraLivre · homologação
Pré-condição	Contas A e B, com dados distintos e fictícios.
Ação	Conta A solicita registro de teste pertencente a B.
Esperado	Acesso negado e nenhum dado de B retornado.
Observado	Solicitação negada sem conteúdo privado.
Resultado	Passou neste caso e nesta versão.

Evidência responsável

- Registre **versão, ambiente, papel, passos e resultado** esperado versus observado.
- Use capturas ou logs **sanitizados**, somente quando forem permitidos.
- Nunca anexe **senhas, tokens, segredos ou dados pessoais** ao relato.

04 / INTERPRETE E COMUNIQUE

O que um resultado realmente prova?

Avalie impacto, limite o parecer e mantenha os controles sob revisão.

Perguntas importantes diante de um achado

- **Quem é afetado?** Uma conta, um grupo ou diferentes perfis?
- **Qual é o impacto?** Houve exposição, alteração indevida ou bloqueio de serviço?
- **Quais condições reproduzem o problema?** Papel, versão, recurso, estado da sessão?
- **O que a evidência permite concluir?** Separe fato observado de hipótese de causa.

Segurança conversa com outros tipos de teste

Perspectiva	Pergunta
Funcional	O comportamento atende à regra de negócio?
Segurança	A ação protege dados, identidade e permissões?
Regressão	Mudanças preservaram controles antes validados?

É possível automatizar verificações estáveis de acesso, autenticação e sessão, combinando-as com revisões de requisitos, mudanças e avaliações especializadas. **Uma suíte curta não comprova que uma aplicação inteira seja segura.**

EXEMPLO DE PARECER TÉCNICO

Escopo: empréstimos, versão X, homologação. **Evidências:** SEG-01 a SEG-04. **Resultado:** critérios atendidos nesses quatro casos. **Limitação:** outras áreas exigem análise. **Próximo passo:** repetir os controles quando permissões mudarem.

Regra de ouro: execute verificações somente em aplicações próprias, laboratórios ou ambientes com autorização explícita. Priorize testes não destrutivos e dados fictícios.

05 / SUA VEZ

Pratique antes da missão

Exercício independente: a LeituraLivre criou um novo papel de monitor.

O papel **monitor** deve consultar relatórios agregados, mas **não** acessar empréstimos individuais de outros associados. Prepare casos de teste sem executar ações em sistemas reais.

Seu desafio

- Escreva **um caso positivo** e **dois casos negativos** para o monitor.
- Diferencie o acesso de alguém **sem login** e de alguém **sem permissão**.
- Defina quais **evidências seguras** guardaria em cada verificação.
- Redija um **parecer limitado ao escopo**, sem afirmar que todo o sistema é seguro.

Checklist de revisão

- [ ] Distingo autenticação, autorização e sessão.
- [ ] Uso contas fictícias e autorização explícita.
- [ ] Verifico permissões no servidor, não apenas na interface.
- [ ] Registro fatos e evidências sem incluir segredos.
- [ ] Limito a conclusão aos casos, ambiente e versão testados.

Referências gratuitas para aprofundar

Fontes oficiais da OWASP, com leitura pública gratuita. Clique para abrir:

01 **OWASP · Web Security Testing Guide**

02 **OWASP · Authentication Cheat Sheet**

03 **OWASP · Authorization Cheat Sheet**

04 **OWASP · Session Management Cheat Sheet**

05 **OWASP · Top 10:2025 em português**